

CP - 2 / Coding for Security

Desenvolvimento de Aplicação Web com Flask

Objetivo

Desenvolver, em grupo, uma aplicação web utilizando o framework Flask, integrando conceitos de desenvolvimento web, banco de dados e segurança.

Os grupos podem ser os mesmos dos CPs anteriores.

Requisitos obrigatórios da aplicação

A aplicação desenvolvida deve atender aos seguintes requisitos:

1. Tema

- A aplicação deve representar um **serviço de tecnologia** (preferencialmente algo que poderia existir no mundo real).

2. Autenticação

- Deve existir uma **área protegida por login**.
- Apenas usuários autenticados devem acessar funcionalidades restritas.

3. Uso de Cookies

- Implementar **um caso real de uso de cookies**, como por exemplo:
 - manter sessão do usuário;
 - salvar preferências (tema, idioma, etc.);
 - lembrar filtros ou configurações da interface.

4. Banco de Dados (SQLite)

- Utilizar **SQLite** como banco de dados.
- Criar pelo menos **uma tabela**.
- Implementar operações de:
 - cadastro (INSERT)
 - consulta (SELECT)
 - edição (UPDATE)
 - exclusão (DELETE)

5. Rotas HTTP

- Utilizar rotas com métodos:
 - **GET**
 - **POST**
- Aplicar corretamente formulários e redirecionamentos.

6. Organização com Flask

- Utilizar:
 - **Blueprints** (organização modular da aplicação)
 - **pelo menos uma Flask Extension**, como:
 - Flask-Login
 - Flask-WTF
 - Flask-SQLAlchemy
 - Flask-Migrate

7. Usabilidade

A aplicação deve apresentar:

- navegação clara;
- interface organizada;
- formulários compreensíveis;
- mensagens de erro e sucesso para o usuário.

8. Vulnerabilidade (Obrigatório)

- O grupo deve:
 - **Inserir propositalmente uma vulnerabilidade**
 - **Demonstrar o ataque durante a apresentação**
 - **Corrigir a vulnerabilidade ao vivo**

Exemplos:

- XSS
- SQL Injection
- IDOR
- falha de autenticação
- upload inseguro

A vulnerabilidade deve ser utilizada apenas para fins didáticos, não coloque o sistema vulnerável em produção!

Escopo mínimo esperado

Para que o trabalho seja considerado completo, espera-se no mínimo:

- login funcional;
- área autenticada;
- pelo menos uma entidade no banco de dados;
- CRUD completo;
- uso de cookie com finalidade clara;
- uso de Blueprint;
- uso de Extension;
- uma vulnerabilidade demonstrada e corrigida.

Critérios de Avaliação (0 a 8 pontos)

1. Apresentação – 1,0 ponto

- participação de todos os integrantes;
- explicação clara do sistema.

2. Vulnerabilidade – 1,0 ponto

- vulnerabilidade demonstrada corretamente;
- impacto explicado;
- correção aplicada durante a apresentação.

3. Relatório – 1,0 ponto

- bem organizado;
- com prints da aplicação;
- descrição das funcionalidades;
- descrição da vulnerabilidade e da correção;
- sem erros graves de português.

4. Código / Aplicação – 1,0 ponto

- sistema funcional;
- rotas organizadas;
- ausência de erros durante execução.

5. Blueprint – 1,0 ponto

- aplicação modularizada;
- uso correto e explicado.

6. Flask Extension – 1,0 ponto

- extensão funcional;
- explicação do seu uso.

7. Banco de Dados – 1,0 ponto

- uso real de SQLite;
- pelo menos uma tabela com operações CRUD.

8. Usabilidade – 1,0 ponto

- interface simples e funcional;
- boa experiência de uso.

Pontuação Extra (até +2 pontos)

9. Vulnerabilidade diferente das vistas em aula – 1,0 ponto

- implementação e correção de uma vulnerabilidade nova.

10. Potencial de uso real (SaaS) – 1,0 ponto

- aplicação com utilidade prática;
- ideia aplicável ao mundo real;
- possível evolução como produto.

Observações finais

- O foco não é criar um sistema grande, mas **um sistema funcional, organizado e bem explicado**.
- Projetos simples, porém bem feitos, terão melhor avaliação do que projetos complexos com falhas.
- A clareza na apresentação e o entendimento do grupo sobre o que foi desenvolvido serão considerados.